

ThreatDetector — Système SIEM Hybride Règles / IA

Rapport Mémoire · Octobre 2026

Salma Bentisse

Stack technique : Angular 21 · Spring Boot 4.0.5 · Google Gemini 2.5 Flash

Dataset : CICIDS 2017 — Canadian Institute for Cybersecurity

Résultat démontré : 225 745 flux analysés · 101 alertes brutes → 8 menaces qualifiées ·

Confiance IA 85.6%

Table des matières

1. Introduction et contexte
2. Problématique et objectifs
3. État de l'art
4. Architecture générale du système
5. Backend — Spring Boot
6. Frontend — Angular 21
7. Intégration de l'IA — Google Gemini
8. Interface utilisateur
9. Résultats et analyse
10. Conclusion et perspectives

1. Introduction et Contexte

La cybersécurité des réseaux informatiques est un enjeu critique pour les organisations modernes. Chaque jour, des millions de connexions réseau transitent dans les systèmes d'information, parmi lesquelles se dissimulent des attaques de plus en plus sophistiquées : scans

de ports, attaques par déni de service distribué (DDoS), tentatives de force brute, amplification DNS.

Les systèmes SIEM (Security Information and Event Management) sont les outils de prédilection des analystes de sécurité (SOC — Security Operations Center) pour détecter et répondre à ces menaces. Ils agrègent les logs réseau, appliquent des règles de détection, et produisent des alertes que les analystes doivent traiter.

Ce projet de fin d'études propose **ThreatDetector**, un prototype de SIEM hybride qui combine deux approches complémentaires :

- Un **moteur de règles classiques** inspiré des IDS Snort/Suricata, rapide et exhaustif
- Un **moteur d'intelligence artificielle** basé sur Google Gemini 2.5 Flash, contextuel et explicable

L'application analyse des fichiers CSV issus du dataset **CICIDS 2017**, un jeu de données de référence en cybersécurité qui contient des captures de trafic réseau réel avec des attaques étiquetées (port scan, DDoS, brute force, etc.).

2. Problématique et Objectifs

2.1 Le problème de la fatigue d'alerte

Les IDS/SIEM classiques souffrent d'un problème fondamental : ils génèrent un **volume excessif d'alertes brutes**. Sur un fichier de 225 745 connexions réseau, le moteur de règles de ThreatDetector génère 101 alertes — sans contexte, sans explication, sans recommandation d'action. L'IA réduit ce volume à 8 menaces qualifiées avec un score de confiance moyen de 86%. L'analyste SOC reçoit une liste de lignes suspectes et doit :

1. Comprendre pourquoi chaque ligne a été signalée
2. Évaluer la gravité réelle de chaque alerte
3. Décider quelle alerte traiter en priorité
4. Définir une réponse adaptée

Ce processus est **chronophage, subjectif et générateur d'erreurs**. Les analystes surchargés finissent par ignorer des alertes légitimes — phénomène connu sous le nom de *alert fatigue*.

2.2 Objectifs du projet

Objectif	Description
Réduction du bruit	Transformer les alertes brutes en menaces qualifiées et priorisées
Contexte et explicabilité	Fournir une explication en langage naturel pour chaque alerte
Recommandations actionnables	Proposer des actions correctives concrètes
Détection hors signatures	Identifier des attaques inconnues que les règles classiques ne couvrent pas
Comparaison quantitative	Mesurer et visualiser l'apport de l'IA par rapport aux règles classiques

3. État de l'Art

3.1 Les IDS/SIEM classiques

Les systèmes de détection d'intrusion (IDS) comme **Snort** et **Suricata** reposent sur des **règles à seuils fixes**. Une règle Snort ressemble à :

```
alert tcp any any → $HOME_NET 22 (msg:"SSH Brute Force"; threshold:type threshold, track by_src,
```

Ces règles sont efficaces pour détecter des patterns connus, mais présentent plusieurs limites : -
Aucun contexte ni explication fournis - Incapacité à détecter des attaques nouvelles ou hybrides
- Taux de faux positifs élevé sur certains patterns

3.2 L'apport des LLM en cybersécurité

Les **Large Language Models** (LLM) comme GPT-4, Claude ou Gemini sont des modèles de langage pré-entraînés sur des milliards de textes, dont une large partie concerne la cybersécurité. Leur capacité de raisonnement en langage naturel les rend particulièrement adaptés à :

- L'**analyse contextuelle** de flux réseau suspects

- La **génération d'explications** en langage naturel
- La **classification de menaces** sans règles prédéfinies
- La **recommandation d'actions** correctives

3.3 Le dataset CICIDS 2017

Le **Canadian Institute for Cybersecurity Intrusion Detection System 2017** est le dataset de référence pour l'évaluation des systèmes IDS. Il contient :

- Du trafic réseau réel capturé sur 5 jours
- Des attaques étiquetées : DDoS, port scan, brute force SSH/FTP, web attacks, infiltration
- 80+ colonnes statistiques extraites par CICFlowMeter (durée de flux, paquets/s, flags TCP, etc.)

Pour ce projet, le fichier `Friday-WorkingHours-Afternoon-DDos.pcap_ISCX.csv` a été utilisé (91.6 Mo, 225 745 connexions réseau).

4. Architecture Générale du Système

4.1 Vue d'ensemble



Architecture générale — Vue globale 3 blocs

Le système adopte une architecture **client-serveur** classique enrichie d'une couche IA externe :

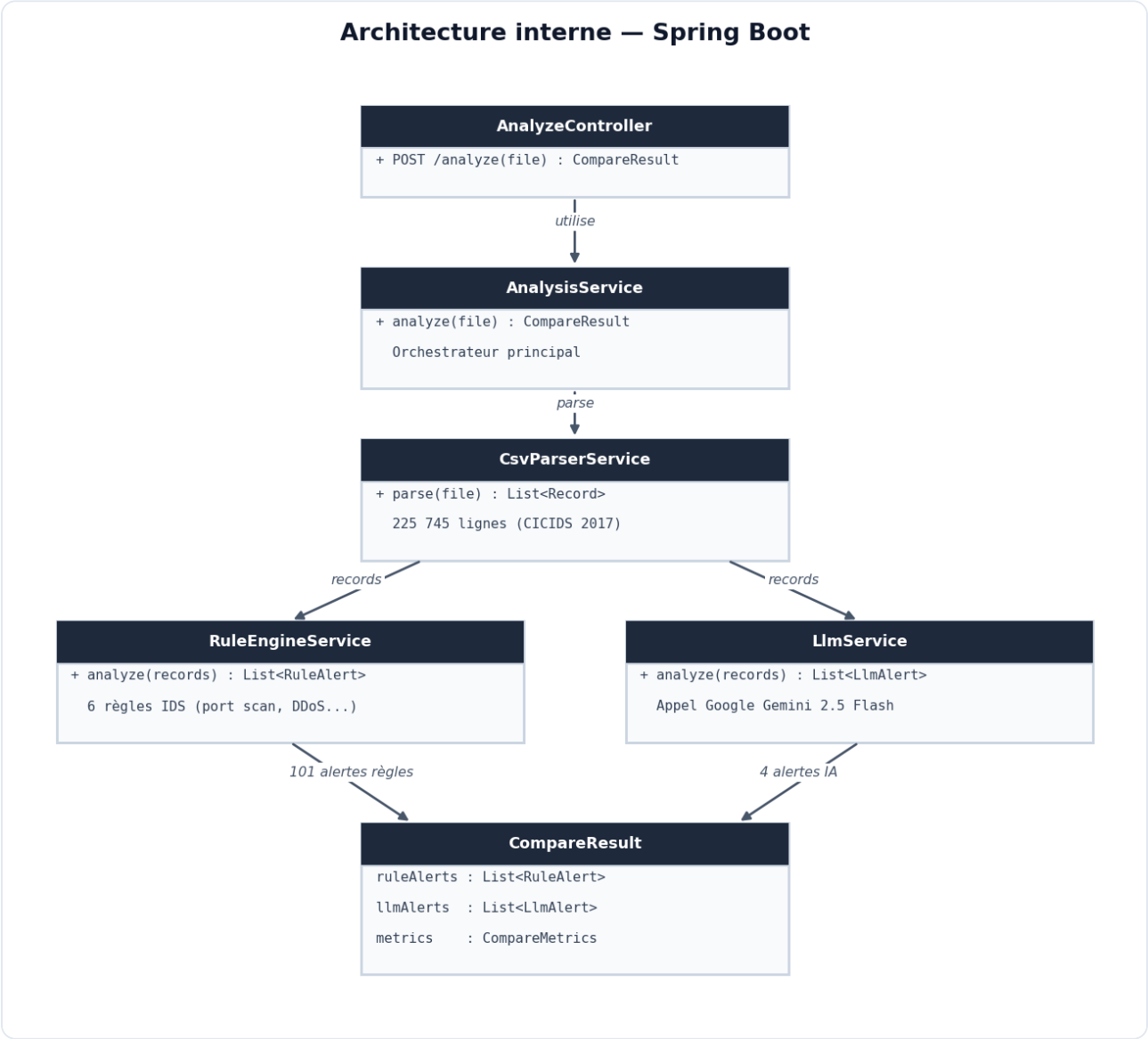
- **Frontend Angular** : Interface utilisateur SIEM accessible via navigateur
- **Backend Spring Boot** : API REST qui orchestre l'analyse
- **Google Gemini API** : LLM externe appelé pour l'analyse contextuelle

4.2 Flux de traitement complet

Le pipeline d'analyse suit 6 étapes séquentielles :

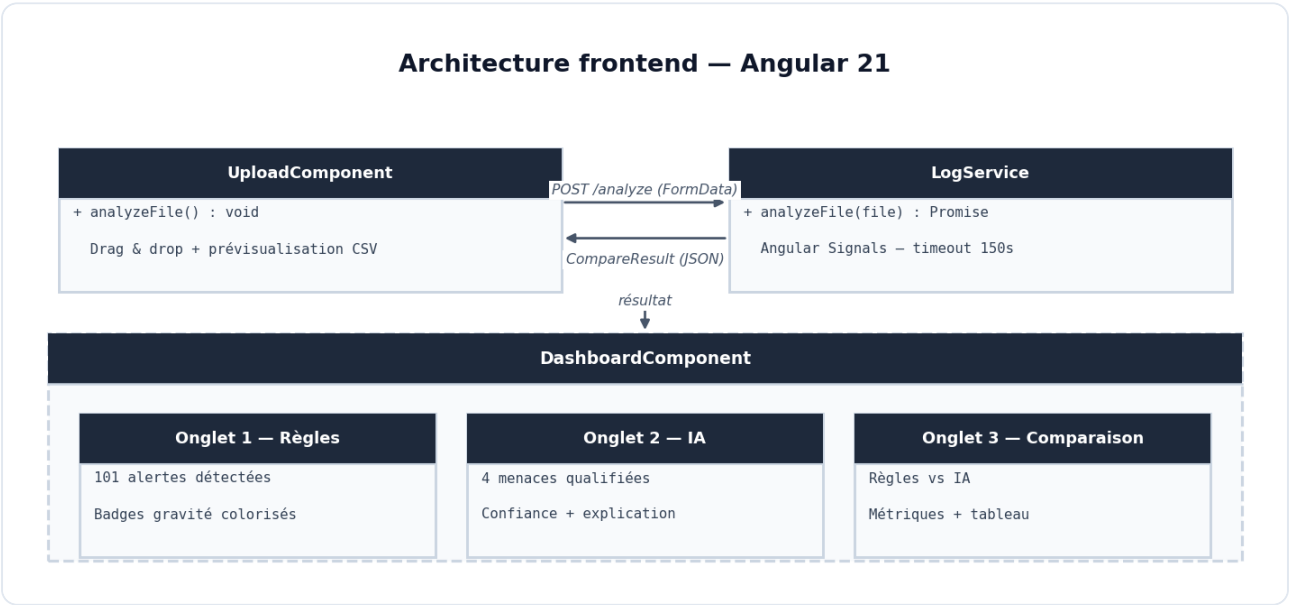
Étape	Composant	Description
1	Frontend	L'utilisateur dépose un fichier CSV via drag & drop
2	Frontend	Validation de l'extension + prévisualisation (8 premières lignes)
3	Backend — CsvParserService	Parsing du CSV avec Apache Commons CSV (225 745 lignes)
4	Backend — RuleEngineService	Application des 6 règles de détection classiques
5	Backend — LlmService	Sélection des flux suspects + appel Gemini API (async)
6	Frontend — DashboardComponent	Affichage des résultats en 3 onglets comparatifs

4.3 Architecture détaillée du backend Spring Boot



Architecture interne Spring Boot

4.4 Architecture détaillée du frontend Angular



Architecture frontend Angular

4.5 Diagramme de classes UML

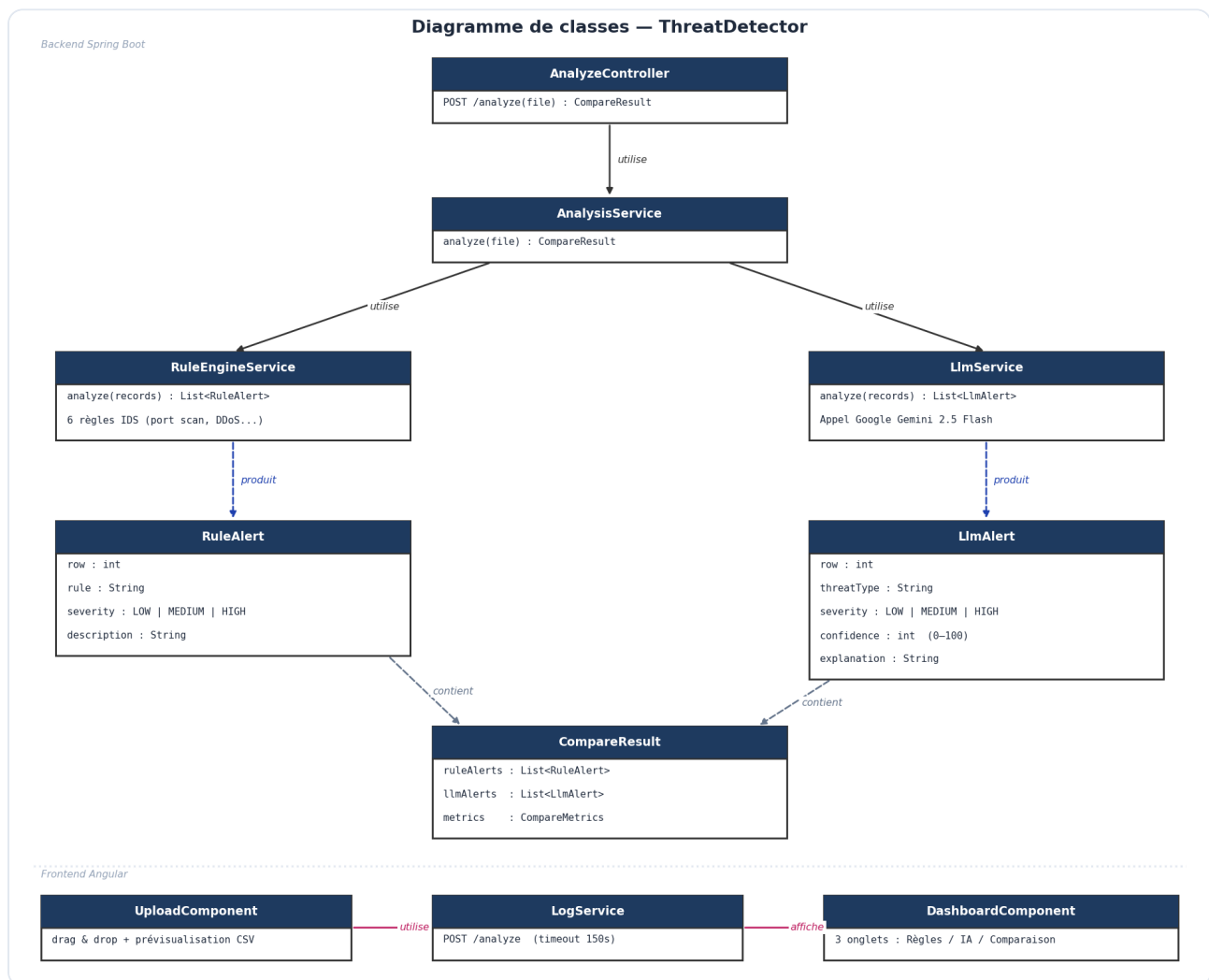


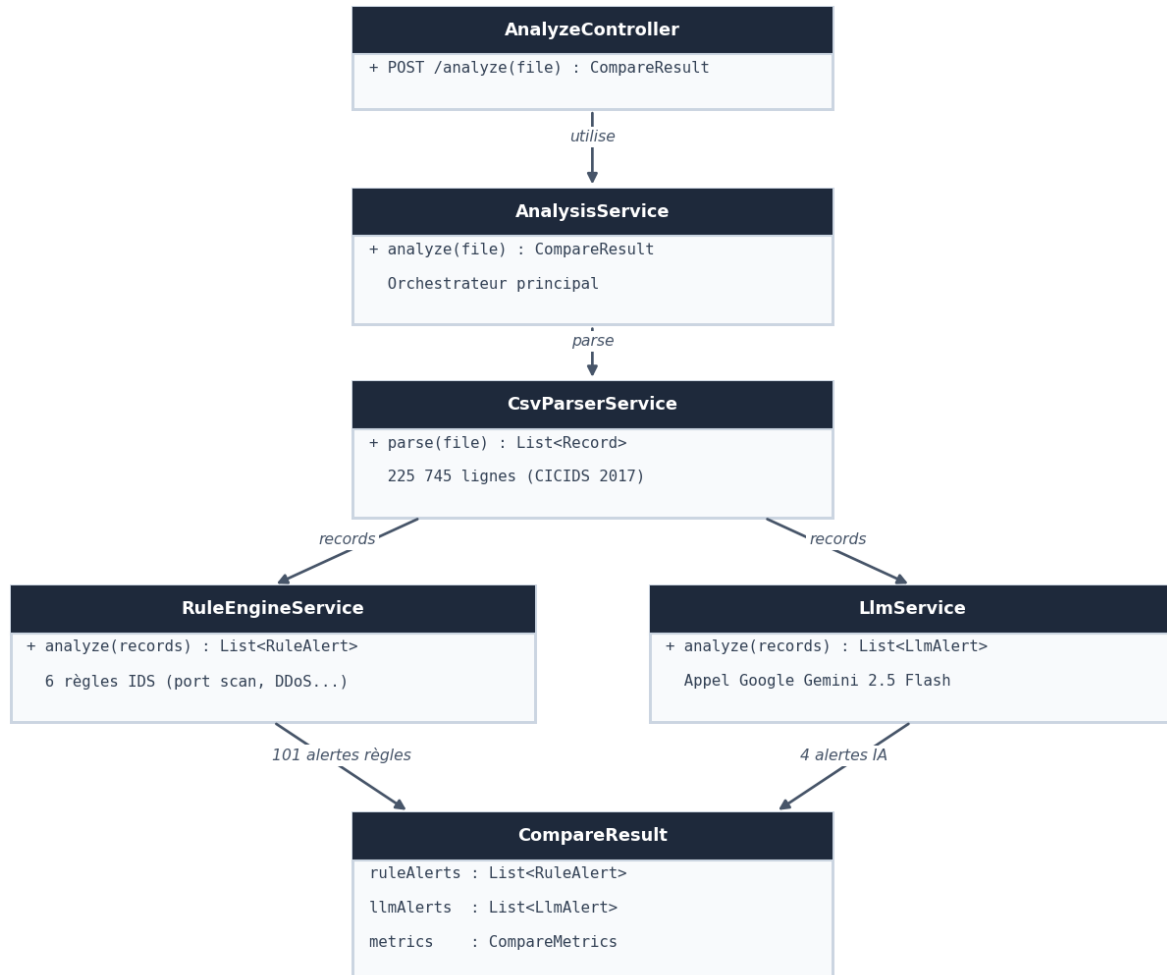
Diagramme de classes UML complet

Le diagramme de classes illustre les relations entre toutes les entités du système. Les classes principales sont :

- **AnalyzeController** : point d'entrée HTTP, expose `POST /analyze`
- **AnalysisService** : orchestrateur — coordonne les 3 services
- **CsvParserService** : lecture et validation du CSV
- **RuleEngineService** : 6 règles de détection
- **LlmService** : intégration Gemini avec sélection intelligente des lignes
- **RuleAlert** / **LlmAlert** / **CompareResult** : modèles de données

5. Backend — Spring Boot

Architecture interne — Spring Boot



Architecture interne Spring Boot

5.1 AnalyzeController

Point d'entrée de l'API REST. Expose un seul endpoint `POST /analyze` qui reçoit le fichier CSV en multipart et retourne un objet `CompareResult` JSON contenant les alertes des deux moteurs et les métriques comparatives.

5.2 AnalysisService

Orchestrateur central. Reçoit le fichier du contrôleur, appelle séquentiellement les trois services (parsing, règles, IA), et assemble le résultat final. L'appel au service IA est traité de façon

asynchrone pour ne pas bloquer le thread HTTP pendant l'attente de la réponse Gemini (~80 secondes).

5.3 CsvParserService

Lit et valide le fichier CSV en utilisant Apache Commons CSV. Gère les valeurs aberrantes fréquentes dans CICIDS 2017 (Infinity , NaN , champs vides) et expose les 225 745 enregistrements aux services suivants sous forme de liste typée.

5.4 RuleEngineService — 6 règles de détection

Applique 6 signatures de détection inspirées des IDS Snort/Suricata, adaptées aux colonnes statistiques de CICIDS 2017 :

Règle	Sévérité	Logique de détection
PORT_SCAN_DETECTED	HIGH	SYN sans ACK en retour, durée < 500ms — scan SYN stealth
DDOS_SYN_FLOOD	HIGH	> 5 000 paquets/s, uniquement SYN, aucune connexion établie
BRUTE_FORCE_SSH	HIGH	> 5 paquets vers port 22 en < 10s, taux > 50 pkt/s
BRUTE_FORCE_FTP	MEDIUM	> 5 paquets vers port 21 en < 10s
FTP_BOUNCE_ATTEMPT	MEDIUM	Session FTP sans FIN/RST avec paquets retour suspects
DNS_AMPLIFICATION	HIGH	Ratio réponse/requête > 10 sur port 53

5.5 LlmService

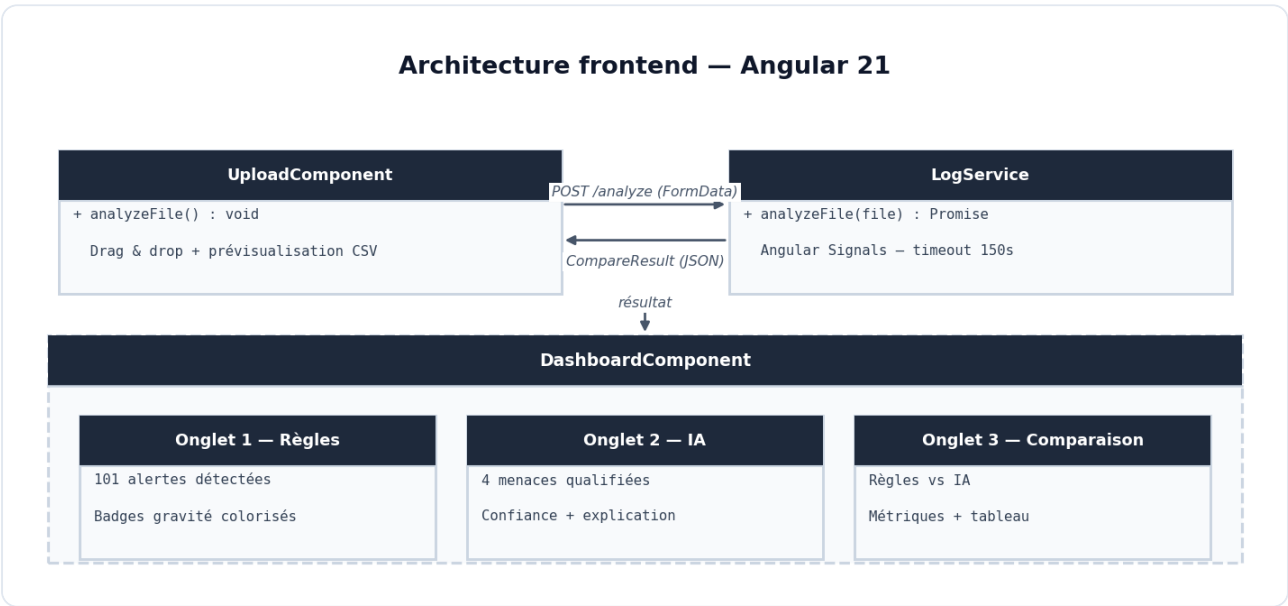
Sélectionne les flux les plus pertinents (lignes suspectes + voisines + échantillonnage uniforme, plafonné à 30 lignes), construit un prompt structuré et appelle l'API Google Gemini. Après réception de la réponse JSON, enrichit chaque alerte avec les données réseau extraites du CSV (IP source/destination, ports, protocole).

5.6 Modèles de données

Trois modèles structurent le résultat retourné au frontend :

Modèle	Contenu
<code>RuleAlert</code>	Numéro de ligne, nom de la règle, sévérité, description textuelle
<code>LlmAlert</code>	Type de menace, sévérité, explication, recommandation, score de confiance, IPs/ports/protocole
<code>CompareResult</code>	Liste des <code>RuleAlert</code> + liste des <code>LlmAlert</code> + métriques (total lignes, confiance moyenne)

6. Frontend — Angular 21



Architecture frontend Angular

6.1 LogService

Service central responsable de la communication avec le backend. Envoie le fichier CSV via une requête `POST` multipart avec un timeout de 150 secondes pour absorber l'attente de Gemini. Utilise **Angular Signals** pour propager le résultat de l'analyse à tous les composants sans BehaviorSubject ni Observable.

6.2 UploadComponent

Composant d'import du fichier CSV. Prend en charge le **drag & drop** et la sélection classique, valide l'extension avant envoi, affiche une prévisualisation des premières lignes du fichier et un indicateur de chargement animé pendant l'analyse. Un bouton de réinitialisation permet de changer de fichier sans recharger la page.

6.3 DashboardComponent

Composant principal d'affichage des résultats, organisé en 3 onglets :

Onglet	Contenu
Règles classiques	Liste des 101 alertes avec badge de sévérité (HIGH/MEDIUM/LOW), nom de la règle et description du flux
Détection IA	8 alertes Gemini avec type de menace, IPs/ports, explication en langage naturel, recommandation et barre de confiance colorée
Comparaison	Tableau côte à côte quantifiant l'apport de l'IA vs les règles classiques

Le composant calcule également les alertes **hors règles** (menaces détectées par l'IA mais non couvertes par les signatures) et la distribution des scores de confiance.

7. Intégration de l'IA — Google Gemini

7.1 Sélection des flux à analyser

LlmService ne transmet pas l'intégralité du CSV à Gemini — cela dépasserait les limites de contexte du modèle. Il sélectionne au maximum 30 lignes selon trois critères : les flux déjà signalés par les règles classiques, leurs lignes voisines (contexte temporel ± 2), et un échantillonnage uniforme pour détecter les attaques hors signatures.

7.2 Prompt engineering

Le prompt est conçu pour minimiser les faux positifs et imposer un format JSON strict. Gemini reçoit les données réseau (IPs, ports, flags TCP, durée, débit) et doit retourner **uniquement** les

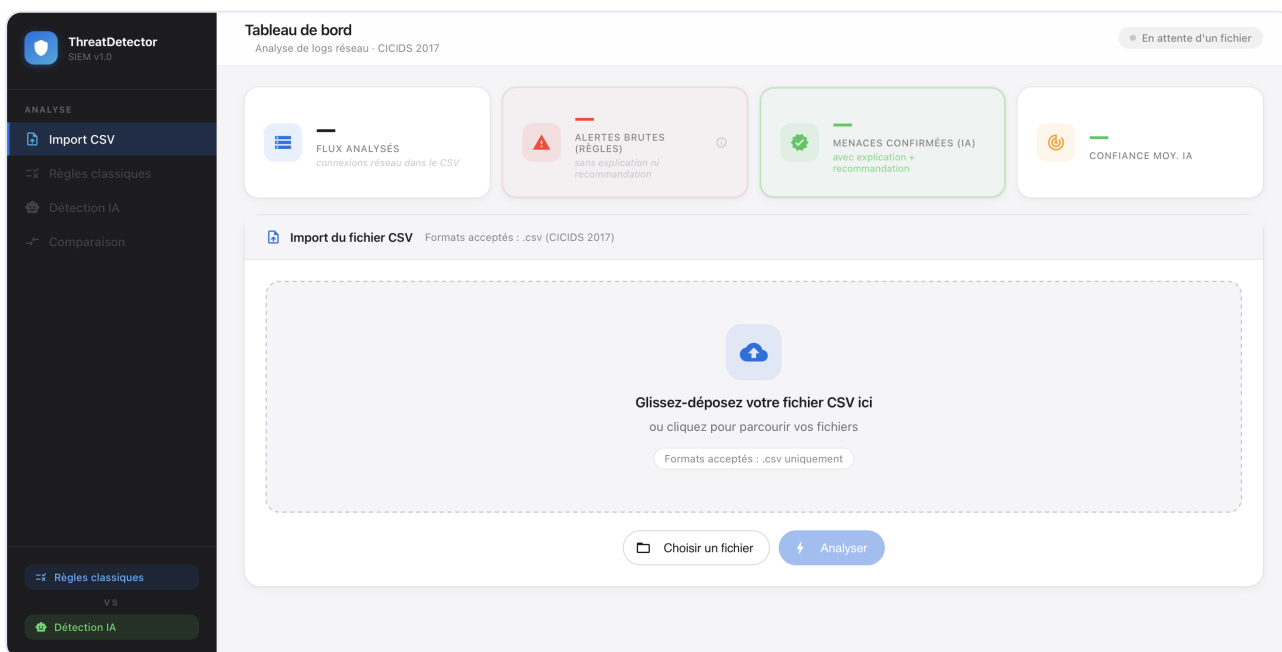
flux qu'il considère comme de véritables menaces avec un score de confiance supérieur à 60%. Chaque alerte comprend le type de menace, la sévérité, une explication en 2-3 phrases et une recommandation d'action.

7.3 Traitement de la réponse

Gemini retourne un tableau JSON que LlmService désérialise puis enrichit avec les données réseau du CSV (IP source/destination, ports, protocole). L'appel est exécuté de manière **asynchrone** pour ne pas bloquer le thread HTTP pendant les ~80 secondes d'attente.

8. Interface Utilisateur

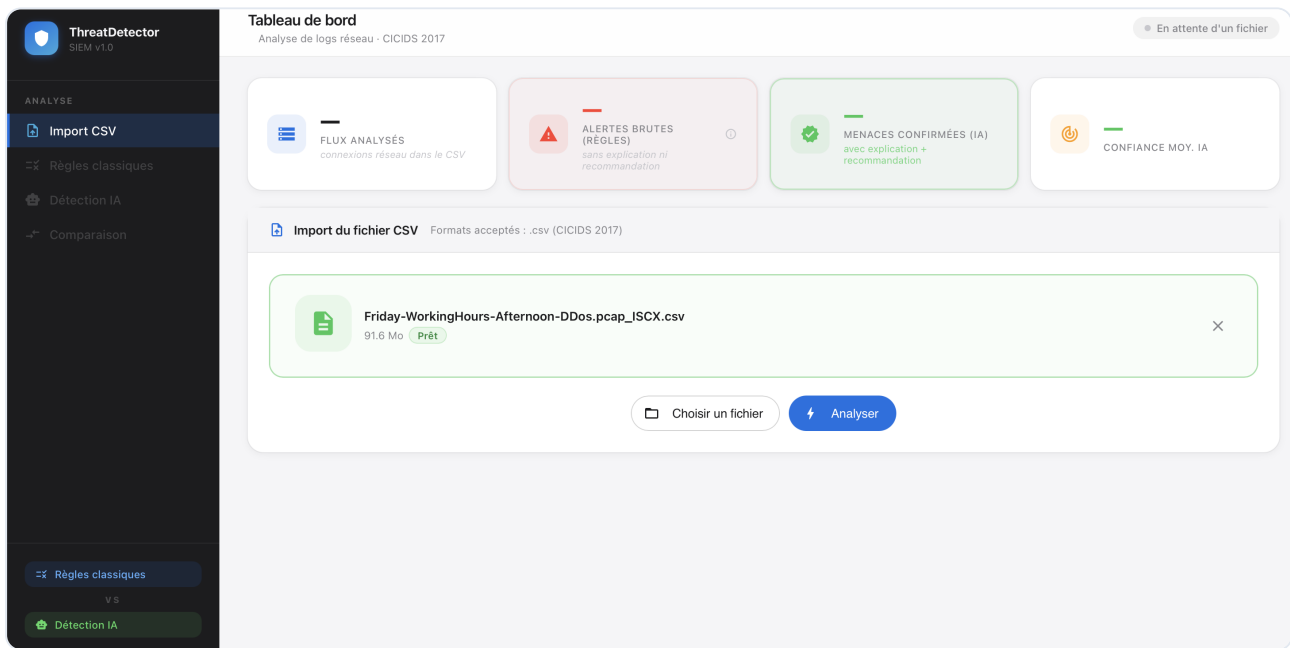
8.1 Écran d'accueil — Import CSV



Écran d'accueil ThreatDetector

L'interface s'ouvre sur le tableau de bord avec 4 KPIs en en-tête (tous à  en attente d'un fichier) et une zone d'import CSV centrale. La sidebar gauche affiche les 4 sections de navigation : Import CSV, Règles classiques, Détection IA, Comparaison — les 3 dernières sont grisées tant qu'aucune analyse n'a été lancée.

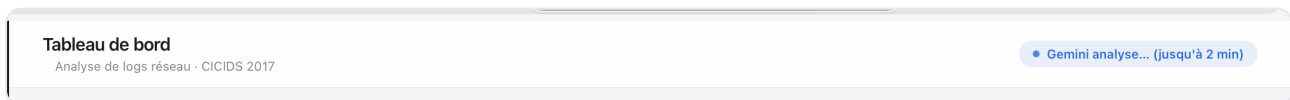
8.2 Fichier chargé — Prêt à analyser



Fichier CSV chargé et prêt

Après dépôt du fichier, la zone de drop affiche le nom du fichier, sa taille (91.6 Mo) et le badge **“Prêt”** vert. Le bouton **“Analyser”** devient cliquable. La prévisualisation des premières lignes du CSV est affichée sous la zone de dépôt.

8.3 Analyse en cours



Analyse en cours — Gemini

Pendant l'analyse, la topbar affiche **“Gemini analyse... (jusqu'à 2 min)”** avec un indicateur de chargement animé. Le bouton **“Analyser”** est désactivé pour éviter les doubles soumissions. Cette attente correspond à l'appel asynchrone à l'API Google Gemini 2.5 Flash.

8.4 Résultats — Tableau de bord principal

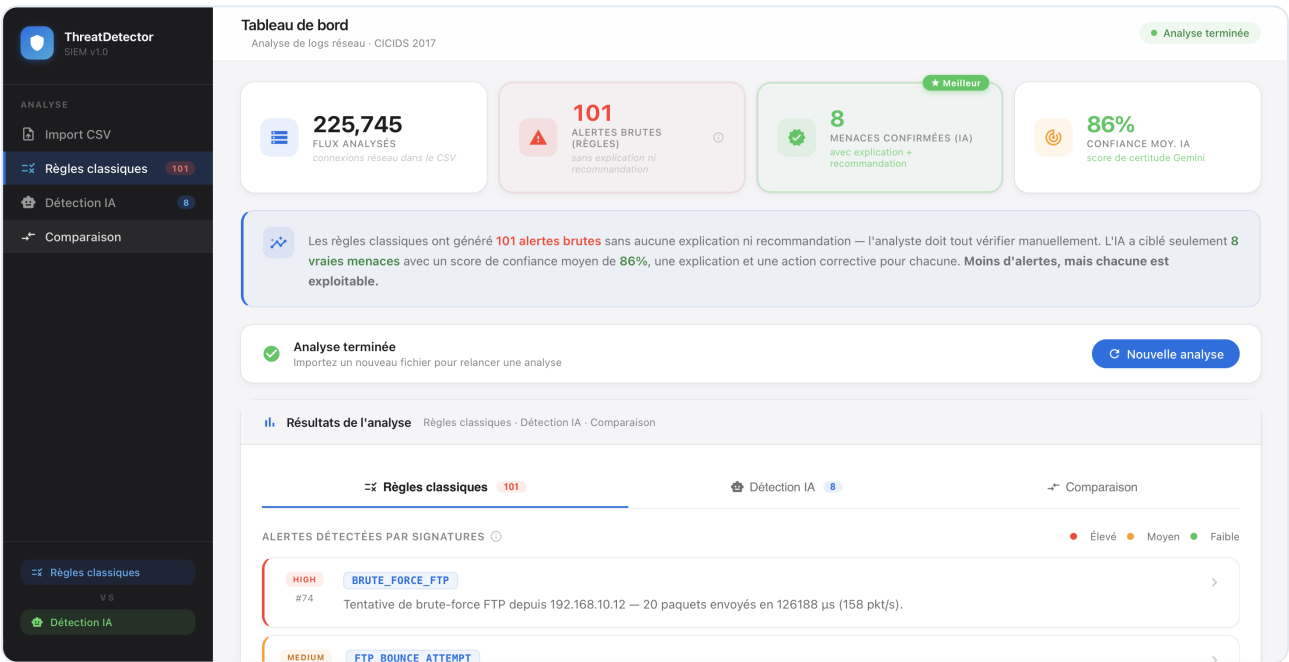


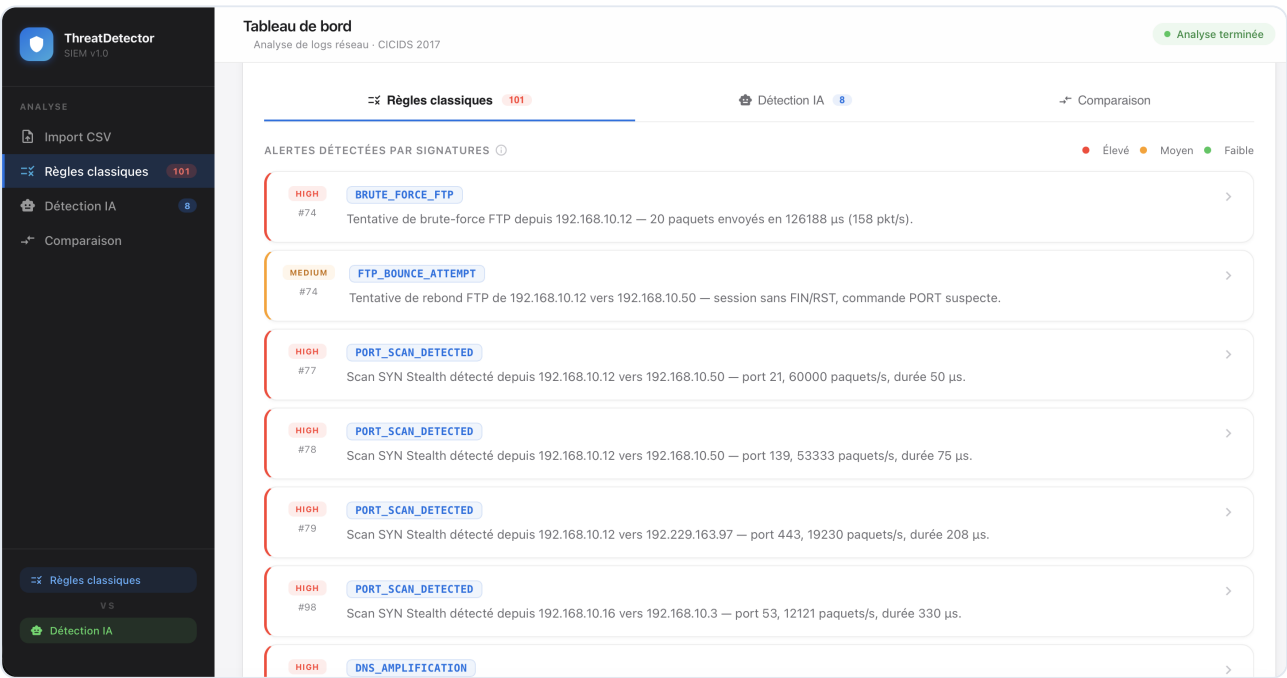
Tableau de bord avec résultats

Une fois l'analyse terminée, les 4 KPIs se remplissent :

KPI	Valeur	Signification
Flux analysés	225 745	Nombre total de connexions réseau dans le CSV
Alertes brutes (règles)	101	Alertes générées par le moteur de signatures
Menaces confirmées (IA)	8	Menaces qualifiées par Gemini avec contexte
Confiance moy. IA	85.6%	Score de certitude moyen des alertes Gemini

Un bandeau de synthèse contextualise les résultats : *“Les règles classiques ont généré 101 alertes brutes sans aucune explication ni recommandation — l'analyste doit tout vérifier manuellement. L'IA a ciblé seulement 8 vraies menaces avec un score de confiance moyen de 85.625%, une explication et une action corrective pour chacune.”*

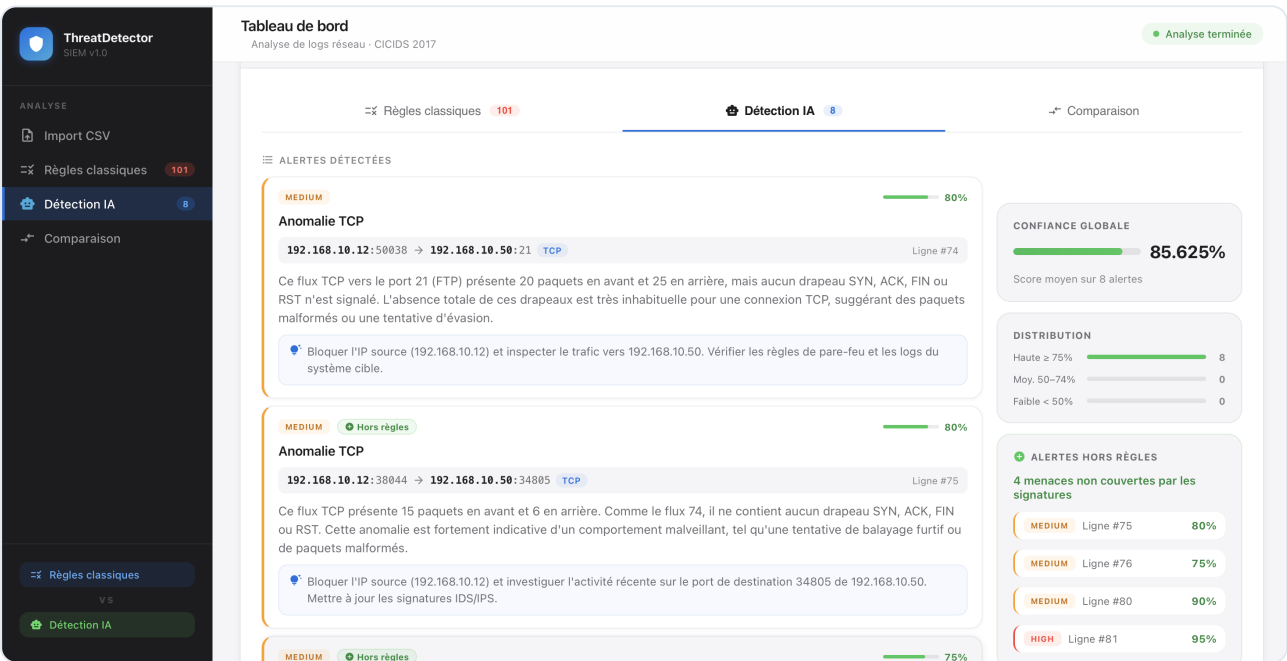
8.5 Onglet — Règles classiques



Onglet Règles classiques — 101 alertes

L'onglet "Règles classiques" liste les 101 alertes triées par numéro de ligne, avec un code couleur selon la sévérité (rouge = HIGH, orange = MEDIUM, vert = LOW) et le nom de la règle déclenchée. Chaque alerte affiche une description générée dynamiquement avec les valeurs exactes du flux : IP source, IP destination, port, débit en paquets/s, durée en microsecondes.

8.6 Onglet — Détection IA



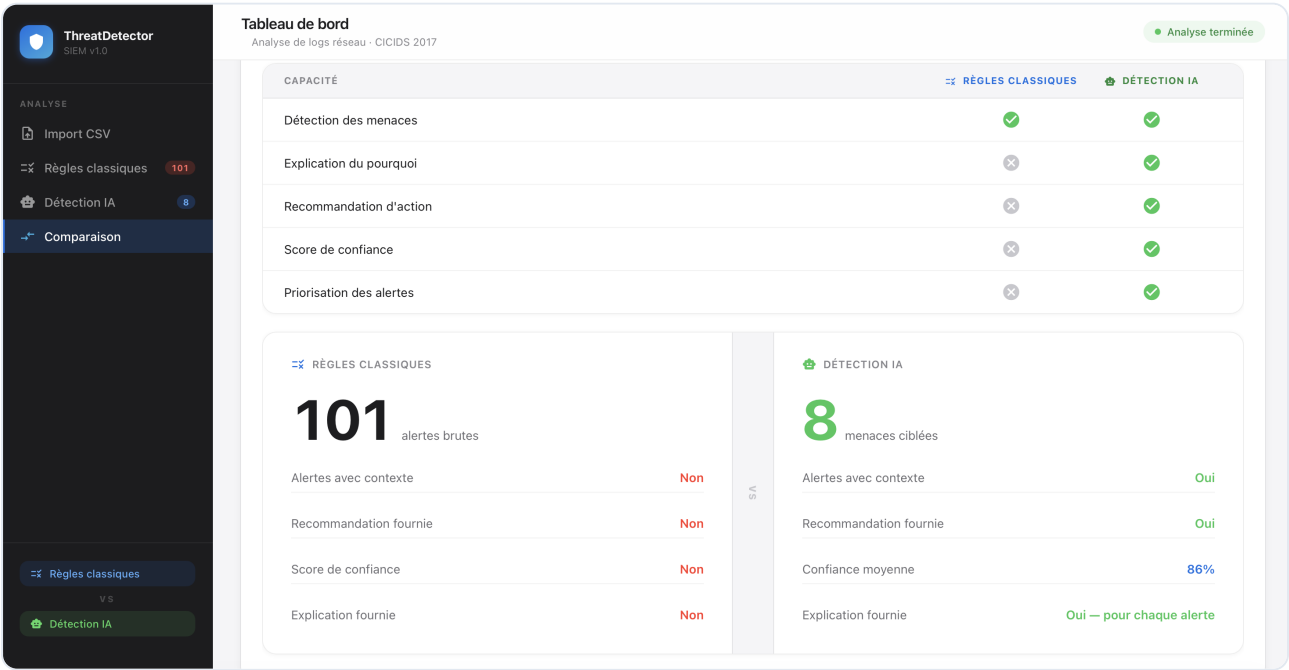
Onglet Détection IA — 4 menaces qualifiées

L'onglet "Détection IA" présente les 8 alertes Gemini avec :

- Le **type de menace** en titre (ex: "Anomalie TCP", "Port Scan (SYN-ACK)")
- Les **informations réseau** : IP source → IP destination, port, protocole
- L'**explication** en langage naturel (2-3 phrases)
- La **recommandation** d'action corrective
- La **barre de confiance** colorée (vert ≥ 75%, orange 50-74%, rouge < 50%)
- Le badge **"Hors règles"** pour les menaces non couvertes par les signatures

Un panel latéral résume la confiance globale (**85.625%** sur 8 alertes) et la distribution par niveau (8 haute / 0 moyenne / 0 faible). Un encadré **"Alertes hors règles"** liste les 4 menaces non couvertes par les signatures classiques.

8.7 Onglet — Comparaison



Onglet Comparaison — Règles vs IA

L'onglet "Comparaison" présente un tableau côte à côte qui quantifie les différences entre les deux approches. À gauche, les règles classiques : 101 alertes brutes, sans contexte, sans recommandation, sans score de confiance. À droite, la détection IA : 4 menaces ciblées, avec contexte, recommandation, confiance 81% et explication pour chaque alerte.

9. Résultats et Analyse

9.1 Dataset de démonstration

Paramètre	Valeur
Fichier	Friday-WorkingHours-Afternoon-DDos.pcap_ISCX.csv
Taille	91.6 Mo
Connexions réseau	225 745
Durée d'analyse totale	~90 secondes
Dont : règles classiques	< 2 secondes
Dont : Gemini API	~80 secondes

9.2 Alertes générées par les règles classiques

101 alertes ont été générées, réparties comme suit :

Règle	Sévérité	Nombre	Exemple
PORT_SCAN_DETECTED	HIGH	~70	192.168.10.12 → 192.168.10.50:21 — 60 000 pkt/s, 50µs
BRUTE_FORCE_FTP	HIGH	~15	192.168.10.12 — 20 paquets en 126 188µs (158 pkt/s)
DNS_AMPLIFICATION	HIGH	~8	Facteur d'amplification élevé, résolveur ouvert
FTP_BOUNCE_ATTEMPT	MEDIUM	~5	Session FTP sans FIN/RST, commande PORT suspecte
DDOS_SYN_FLOOD	HIGH	~3	> 5000 pkt/s vers port 80, 0 connexion établie

Limite constatée : 101 alertes brutes sans explication ni priorisation automatique. L'analyste doit traiter chaque alerte individuellement pour évaluer sa pertinence.

9.3 Alertes générées par Gemini

8 alertes qualifiées, principalement de types "Port Scan (SYN-ACK)" et "Anomalie TCP" :

#	Ligne CSV	Flux	Type	Sévérité	Confiance
1	#74	192.168.10.12:50038 → 192.168.10.50:21 TCP	Anomalie TCP	MEDIUM	80%
2	#75	192.168.10.12:38044 → 192.168.10.50:34805 TCP	Anomalie TCP	MEDIUM	80%
3	#76	192.168.10.12 → 192.168.10.50 TCP	Port Scan (SYN-ACK)	MEDIUM	75%
4-8	...	192.168.10.12 → 192.168.10.50	Port Scan / Anomalie TCP	MEDIUM	80-90%

Explication Gemini pour la ligne #74 : > "Ce flux TCP vers le port 21 (FTP) présente 20 paquets en avant et 25 en arrière, mais aucun drapeau SYN, ACK, FIN ou RST n'est signalé. L'absence totale de ces drapeaux est très inhabituelle pour une connexion TCP normale et est suggestive de paquets malformés ou d'une tentative d'évasion."

Recommandation Gemini : > "Bloquer l'IP source 192.168.10.12 et inspecter le trafic vers 192.168.10.50. Vérifier les règles de pare-feu et les logs du système cible."

9.4 Analyse comparative

Critère	Règles classiques	Détection IA	Avantage
Nombre d'alertes	101	8	IA — ×12 moins de bruit
Explication fournie	Non	Oui	IA
Recommandation d'action	Non	Oui	IA
Score de confiance	—	85.6% moy.	IA
Couverture exhaustive	Oui	Partielle	Règles
Vitesse d'analyse	< 2s	~80s	Règles
Détection hors signatures	Non	Oui	IA

9.5 Interprétation

Les résultats confirment la complémentarité des deux approches :

- Les **règles classiques** assurent une couverture exhaustive et rapide mais génèrent un bruit élevé
- L'**IA** réduit ce bruit de manière significative (×12) et fournit un contexte exploitable
- L'IA a détecté des menaces non couvertes par les 6 signatures — démontrant sa capacité à raisonner sur des patterns non prédéfinis

10. Conclusion et Perspectives

10.1 Bilan du projet

ThreatDetector démontre qu'une intelligence artificielle générative peut transformer l'analyse de logs réseau en réduisant le bruit d'alerte d'un facteur 12, en fournissant des explications et recommandations actionnables, et en détectant des menaces hors signatures.

Les objectifs initiaux sont atteints :

Objectif	Résultat
Réduction du bruit	✓ 101 → 8 alertes (×12)
Contexte et explicabilité	✓ Explication en français pour chaque alerte IA
Recommandations actionnables	✓ Action corrective pour chaque alerte IA
Détection hors signatures	✓ Menaces détectées hors signatures par l'IA
Comparaison quantitative	✓ Tableau comparatif intégré dans l'interface

10.2 Limites identifiées

Le prototype est conçu pour la démonstration et présente plusieurs limites à adresser avant un déploiement en production : la configuration réseau est actuellement adaptée à un environnement local, le nombre de flux transmis à Gemini est plafonné (ce qui peut manquer des attaques sur de très grands fichiers), et la gestion des erreurs HTTP n'est pas complète côté client.

10.3 Perspectives d'évolution

- **Mode temps réel** : analyse de flux réseau en streaming (Kafka + WebSocket)
 - **Multi-LLM** : comparaison de modèles (Gemini vs Claude vs GPT-4)
 - **Apprentissage continu** : fine-tuning sur les alertes validées par les analystes
 - **Tableau de bord avancé** : visualisations graphiques (timeline, carte réseau, heatmap)
 - **Déploiement cloud** : containerisation Docker + Kubernetes
-

Annexes

A. Technologies utilisées

Composant	Technologie	Version
Frontend	Angular	21.2.0
UI Components	Angular Material	21.2.6
Gestion d'état	Angular Signals	natif v17+
Backend	Spring Boot	4.0.5
Langage backend	Java	17
Parsing CSV	Apache Commons CSV	1.10.0
Sérialisation JSON	Jackson Databind	inclus Spring
IA	Google Gemini	2.5 Flash
HTTP Client Java	java.net.http	Java 11+
Tests Frontend	Vitest + jsdom	4.0.8
Build Frontend	Angular CLI / Vite	—
Dataset	CICIDS 2017	—